



Análise Crítica da Literatura

🕒 Created 2 de maio de 2026 17:17

Tema:

Cyber Range open-source para ETE | Ataques MitM/FDI e Defesa Ativa em Modbus TCP

Destino:

Trilha da Indústria — SBSeg 2026

1. O Artigo Âncora (Prior Work)

Artigo âncora principal: Mathur & Tippenhauer (2016) — "SWaT: A Water Treatment Testbed for Research and Training on ICS Security"

Este é, sem dúvida, o trabalho fundacional que sustenta todo o seu projeto. Os motivos são objetivos:

Proximidade temática perfeita: O SWaT é um cyber range de uma planta de tratamento de água com 6 estágios controlados por CLPs, comunicação de rede industrial e SCADA — estrutura quase idêntica à sua ETE virtual. O problema que você resolve ("como fazer pesquisa ofensiva e defensiva em ICS sem risco a plantas reais") é exatamente a motivação declarada do SWaT.

Rigor metodológico e peso institucional: Publicado no IEEE, desenvolvido pelo iTrust Lab (SUTD, Singapura), com infraestrutura física avaliada em centenas de milhares de dólares. Citar o SWaT diz ao revisor que você conhece o estado da arte internacional de referência.

Impacto na literatura: O SWaT gerou dezenas de trabalhos derivados sobre detecção de intrusão, FDI e defesa em ICS, tornando-se o benchmark mais referenciado do nicho. O revisor do SBSeg reconhecerá o nome.

Artigo âncora secundário: Morris & Gao (2014) — "ICS Traffic Data Sets for Intrusion Detection Research"

Complementa o SWaT ao estabelecer a prática de capturar tráfego Modbus sob ataque (28 ataques contra dois testbeds laboratoriais, incluindo tanques de água) para benchmarking de detectores de intrusão. Morris justifica a sua escolha pelo protocolo Modbus TCP como vetor de ataque e legitima o uso de datasets próprios como contribuição científica válida.

Artigo de contexto histórico: Beresford (2011) — "Exploiting Siemens Simatic S7 PLCs"

Serve como marco histórico para demonstrar que CLPs comerciais, projetados sem segurança ("air gap assumption"), são sistematicamente vulneráveis a replay attacks, fingerprinting e injeção de comandos — argumento que justifica por que o Modbus TCP do OpenPLC também é vulnerável sem criptografia.

2. Definição do Foco e Análise de Lacunas (The Gap)

Ao cruzar os trabalhos, três lacunas combinadas formam o espaço exclusivo do seu artigo:

Lacuna 1 — Custo e replicabilidade dos cyber ranges:

O SWaT (hardware proprietário Allen-Bradley, infraestrutura física de 90 m²) e os testbeds de Morris (hardware laboratorial físico) são **irreproduzíveis** por grupos de pesquisa sem financiamento robusto. Nenhum deles usa arquitetura 100% open-source virtualizada em Docker. A literatura nacional não possui cyber range documentado de ETE com essa pilha tecnológica.

Lacuna 2 — FDI em domínio de efluentes:

Liu, Ning & Reiter (2011), trabalho fundacional sobre FDI, formulou o ataque no domínio de redes elétricas (estimação de estado em power grids). A maioria dos trabalhos de FDI em ICS continua nesse domínio ou em redes de distribuição de água potável. A aplicação de FDI via Modbus TCP em uma ETE (tratamento de efluentes) com validação experimental em registradores reais (Holding Registers FC03/04) é inédita na literatura nacional consultada.

Lacuna 3 — Defesa ativa na Camada 2 como neutralizador de ataques nas camadas superiores:

A maioria dos mecanismos de defesa propostos para ICS opera nas camadas de aplicação (detecção de anomalias no tráfego Modbus, firewalls de protocolo) ou transporte (VPN, TLS). Seu experimento demonstrou empiricamente que a imunização da Camada 2 via *Gratuitous ARP* bidirecional **invalida completamente** ataques MitM/FDI nas Camadas 4 e 7 — sem exigir

criptografia nos dispositivos legados. Esse resultado ainda não aparece documentado experimentalmente em cyber ranges open-source.

Pergunta de Pesquisa proposta:

"É possível construir um cyber range de baixo custo, baseado integralmente em ferramentas open-source e virtualização Docker, para reproduzir ataques de Falsa Injeção de Dados via Modbus TCP em uma ETE virtual e demonstrar experimentalmente a eficácia de um mecanismo de Defesa Ativa na Camada de Enlace como contramedida?"

Foco principal do artigo: Arquitetura + ataque + defesa, com os três integrados em um pipeline experimental reproduzível.

3. Esqueleto do Artigo (Estrutura Proposta)

1. Introdução

- Contextualizar a convergência IT/OT e a exposição de infraestruturas críticas (ETEs) a ataques cibernéticos. Citar Beresford (2011) para o precedente histórico de vulnerabilidade em CLPs.
- Motivar o problema: pesquisa em ICS requer ambientes seguros de teste; plantas reais não podem ser usadas. Citar Mathur & Tuppenhauer (2016) — "many algorithms are assessed using simulation or numerically".
- Declarar a lacuna: cyber ranges existentes são caros e fechados; FDI em ETE não foi validado experimentalmente em contexto nacional open-source.
- Enunciar as contribuições: (i) cyber range open-source de ETE; (ii) demonstração de FDI via Modbus TCP; (iii) defesa ativa na Camada 2.

2. Trabalhos Relacionados

- **2.1 Vulnerabilidades em CLPs e Protocolos Industriais:** Beresford (2011) — ausência de autenticação no S7 e no Modbus. Fritz/UFRJ (2017) — contexto de automação de ETE no Brasil (uso para mostrar relevância prática nacional).
- **2.2 Cyber Ranges para ICS/SCADA:** Morris & Gao (2014) — primeiros testbeds documentados; SWaT/Mathur (2016) — benchmark internacional. Contrastar com a sua arquitetura open-source.

- **2.3 Ataques de Falsa Injeção de Dados:** Liu, Ning & Reiter (2011) — formalização do FDI em redes elétricas. Mostrar a extensão ao domínio Modbus TCP em ETE.
- **2.4 Mecanismos de Defesa em Redes OT:** Lacuna identificada — defesa ativa na Camada 2 não documentada experimentalmente em cyber ranges open-source de ICS.

3. Arquitetura do Cyber Range

- Descrever os três componentes: OpenPLC (lógica ST/IEC 61131-3), FUXA SCADA (IHM web), Gêmeo Digital Python (simulação física dos tanques).
- Topologia Docker: containers kali-rolling (atacante), fuxa (vítima/IHM), comunicação Modbus TCP porta 502 sem criptografia.
- Referência cruzada com SWaT (Mathur, 2016) para legitimar a equivalência funcional.

4. Metodologia dos Ataques

- **4.1 MitM via ARP Poisoning + Manipulação de Atuador (Bomba 1):** Referência ao relatório Testes MitM (dez/2025). Scapy + ARP bidirecional.
- **4.2 False Data Injection em Sensor de Nível (FC03/04 Holding Registers):** Relatório Semana 2 (jan/2026). Script `attack_level.py`. Demonstração do efeito de Decoupling: SCADA lê nível falso, CLP age sobre o processo real — divergência entre estado virtual e físico.
- Referência conceitual: Liu, Ning & Reiter (2011) para o modelo de FDI; Morris & Gao (2014) para a classe de ataque Modbus.

5. Mecanismo de Defesa Ativa

- Descrição do IPS baseado em *Gratuitous ARP* bidirecional (`defesa_ativa.py`).
- Protocolo de validação experimental em 5 terminais.
- Resultado: supervisor Fuxa manteve leitura estável do nível mesmo sob ARP Spoofing duplo e DROP de pacotes Modbus (iptables).
- Argumento central: imunização da Camada 2 neutraliza ataques nas Camadas 4 e 7 — relevante para operadores com dispositivos legados que não suportam TLS.

6. Resultados e Discussão

- Tabela comparativa: estado do sistema (nível do tanque no SCADA vs. real) com e sem ataque, com e sem defesa.
- Capturas de tela do alerta de segurança (`detect_mitm.py`) disparado imediatamente ao acionar os terminais de envenenamento.
- Discussão sobre aplicabilidade a infraestruturas reais que usam Modbus legado.

7. Conclusão

- Síntese das três contribuições. Limitações (ambiente virtualizado, ausência de ruído físico real). Trabalhos futuros: extensão a DNP3, adição de detecção baseada em invariantes de processo (referência ao SWaT).

4. Definição de Métricas de Comparação

Com base nos artigos analisados, as métricas que você é obrigada a incluir são:

Métricas de ataque (obrigatórias para comparação com Morris 2014 e SWaT):

Taxa de Sucesso do Ataque (Attack Success Rate): Percentual de pacotes Modbus FDI efetivamente entregues ao SCADA antes da defesa ser ativada. Morris (2014) usa essa métrica para classificar ataques.

Divergência de Estado (State Decoupling): Diferença entre o valor lido pelo SCADA (valor falso injetado) e o valor real do processo. No seu experimento, o nível falso foi fixado em um valor constante enquanto o gêmeo digital continuava simulando o processo. Expressar em unidades de engenharia (% , cm ou unidades de registrador Modbus).

Tempo de Detecção (Time-to-Detect): Intervalo entre o início do envenenamento ARP (ativação dos terminais 3 e 4) e o primeiro alerta disparado pelo `detect_mitm.py` . Seu relatório de mitigação indica que o alerta foi quase imediato — quantifique em milissegundos ou segundos.

Métricas de defesa (obrigatórias):

Taxa de Neutralização do Ataque: Com a Defesa Ativa ativa (Terminal 2), o SCADA manteve leitura estável (0% de pacotes FDI aceitos). Isso precisa ser expresso como uma comparação antes/depois.

Overhead da Defesa: Frequência de envio dos pacotes *Gratuitous ARP* (a cada 0,5 s no seu script). Verificar se essa frequência introduz latência perceptível nas respostas Modbus TCP normais — mesmo que pequena, reportar.

Disponibilidade do Sistema: O DoS via `iptables DROP` (porta 502) causou timeout na IHM Fuxa. Com a defesa ativa, a conexão permaneceu estável. Reportar como tempo médio de resposta Modbus ou taxa de timeouts.

5. Projeção de Resultados

Para que o artigo seja aceito pelos revisores do SBSeg (Trilha da Indústria), você precisa provar as três teses a seguir com dados experimentais:

Tese 1 — O cyber range é funcionalmente equivalente a uma planta real para fins de pesquisa em segurança:

Mostrar que o sistema em condições normais se comporta de forma estável e consistente (leitura de nível pelo SCADA acompanha a simulação física do gêmeo digital). Um gráfico de linha simples mostrando a leitura do SCADA vs. a simulação do gêmeo digital ao longo do tempo, sem ataque, é suficiente.

Tese 2 — O ataque FDI via Modbus TCP é eficaz e perigoso:

Um gráfico temporal mostrando o momento em que o `attack_level.py` é ativado e a leitura do SCADA congelando no valor falso (e.g., nível = 0 ou nível fixo alto), enquanto o gêmeo digital continua evoluindo normalmente, demonstra visualmente o Decoupling. Esse é o gráfico mais importante do artigo — o revisor precisa "ver" o perigo.

Tese 3 — A Defesa Ativa na Camada 2 neutraliza completamente o ataque:

Um gráfico ou tabela comparando três cenários: (a) operação normal, (b) ataque sem defesa, (c) ataque com defesa ativa. No cenário (c), a leitura do SCADA deve ser indistinguível do cenário (a). Complementar com o log de alertas do `detect_mitm.py` mostrando a detecção instantânea.

6. Base de Síntese — Tabela de Referência Rápida

Autor(es) & Ano	Foco Principal do Estudo	Metodologia / Hardware Usado	Principal Limitação (Oportunidade para o artigo)
Mathur & Tippenhauer (2016) — SWaT	Cyber range físico de planta de tratamento de água; avaliação de	Testbed físico com PLCs Allen-Bradley, EtherNet/IP (ENIP), SCADA proprietário;	Hardware proprietário, irreproduzível por grupos sem grande

Autor(es) & Ano	Foco Principal do Estudo	Metodologia / Hardware Usado	Principal Limitação (Oportunidade para o artigo)
	ataques e defesas em ICS com 6 estágios de CLPs	infraestrutura institucional de alto custo	financiamento; sem componente de gêmeo digital; não trata especificamente FDI via Modbus
Morris & Gao (2014)	Geração de datasets de tráfego ICS para benchmarking de IDS; 28 ataques (reconhecimento, injeção, DoS) em testbeds Modbus	Dois testbeds físicos laboratoriais (tanque de água + duto de gás); protocolo Modbus/TCP; captura com Wireshark	Sem proposta de defesa; datasets públicos mas o testbed não é virtualizado; ausência de análise de eficácia de contramedidas
Beresford (2011)	Exploração de vulnerabilidades em CLPs Siemens S7 (replay attack, fingerprinting, autenticação fraca, injeção de comandos)	Testes em Simatic S7-300/400/1200; protocolo ISO-TSAP / S7Comm; Black Hat USA	Hardware proprietário (S7); não aborda Modbus TCP; sem contramedidas propostas; contexto pré-Stuxnet sem ambiente virtualizado
Liu, Ning & Reiter (2011)	Formalização matemática de FDI em redes elétricas; demonstração de bypass de detectores de dados inconsistentes (bad data detectors)	Modelagem matemática de estimação de estado em power grids; sem testbed físico	Domínio restrito a redes elétricas; modelo teórico sem validação experimental em Modbus; não aborda contramedidas na Camada 2
Fritz / UFRJ (2017)	Automação de ETE com CLP Siemens; lógica de controle de bombas e válvulas em planta real de esgoto	CLP Siemens S7, SCADA proprietário, instrumentação física de planta real	Ausência total de análise de segurança cibernética; contexto de engenharia de controle puro; não

Autor(es) & Ano	Foco Principal do Estudo	Metodologia / Hardware Usado	Principal Limitação (Oportunidade para o artigo)
			aborda vulnerabilidades do protocolo de comunicação
Matos (2025-2026) — Este trabalho	Cyber range open-source de ETE (OpenPLC + FUXA + Gêmeo Digital Python); ataques MitM/FDI via Modbus TCP; Defesa Ativa ARP Camada 2	Docker (kali-rolling, fuxa); Scapy/NetfilterQueue; arpspoof ; Gratuitous ARP bidirecional; ambiente UNIFEI/PIBIT	Ambiente inteiramente virtualizado (sem ruído físico real); testado em topologia de rede única; extensão a outros protocolos (DNP3, EtherNet/IP) como trabalho futuro